Examen Parcial 1 – Parte Practica

- Nombre del estudiante: Abraham Núñez Sánchez

- Fecha: 15 de octubre del 2026

1. Diagnostico inicial

Antes de modificar el servidor, realiza una revisión general que permita conocer su estado actual. Deberás revisar usuarios y privilegios, cuentas temporales, servicios y puertos, configuración SSH y banner, firewall, permisos de archivos sensibles, almacenamiento y estado del cifrado. Conserva evidencia delestado encontrado.

2. Identificación y análisis de riesgos

A partir del diagnóstico, identifica las configuraciones que consideres inseguras o inadecuadas. Por cadahallazgo describe la situación encontrada, el riesgo, el impacto y el control necesario. Indica también sipuede afectar principalmente a la confidencialidad, integridad o disponibilidad de la información o delservicio.

3. Aplicaciones de controles

Corrige las configuraciones que puedan modificarse de manera segura durante el examen. Las correcciones deberán considerar lo trabajado durante el curso sobre mínimo privilegio, cuentas temporales, SSH, banner, firewall de host, permisos, llaves criptográficas y protección de información. En el caso del almacenamiento cifrado, no será necesario convertir el volumen a LUKS durante el examen;deberás realizar el diagnóstico y explicar la solución que aplicarías.

4. Verificación

Después de realizar las correcciones, demuestra que los controles funcionan. Cuando corresponda, realiza una prueba positiva para demostrar que una actividad autorizada continúa funcionando y una prueba negativa para demostrar que una actividad que no debería permitirse es rechazada. Podrás utilizarcliente-examen para realizar estas comprobaciones.

5. Análisis del almacenamiento

Determina si el volumen destinado a información de clientes se encuentra protegido mediante cifrado. Explica brevemente la situación encontrada, el riesgo, la tecnología que utilizarías, cómo comprobarías que el volumen quedó protegido y qué riesgo permanecería cuando el volumen estuviera desbloqueado.

Hallazgo	Evidencia inicial	Riesgo e impacto	Control o corrección	Evidencia final
Múltiples usuarios con permisos root en el servidor, algunas de ellas están duplicadas como Soporte y soporte	Revisando el archivo /etc/passwd se encontraron los usuarios: - vboxuser - adminsys - Soporte (este no esta en el grupo de sudo) - soporte - temporal (este no esta en el grupo de sudo)	Vectores de riesgo ya que aumentan la probabilidad de alguna violación a la triada CIA mediante estos usuarios.	- sudo gpasswd -d soporte sudo, si se necesita algo puntual, un archivo en sudoers.d con solo esos comandos - Bloquear o eliminar la innecesaria: sudo usermod -L -e 1 Soporte	Imagen 1
Servicios expuesto	Mediante los comandos ss -tulpn y systemctl se encontraron los servicios de apache y ssh abiertos	Acceso no autorizado a estos servicios.	- Activar un firewall y mejorar la configuración de cada servicio.	Imagen 2 y 3
Firewall desactivado	UFW esta inactivo e Iptables no tiene ninguna regla, esto mediante la revisión de ufw status e iptables -L -n -v	Servidor que permite conexiones de cualquier externo sin protección	- Activar UFW y aplicar reglas en Iptables - UFW con deny y configuración solo 22 y 80	Imagen 4
Usuario temporal sin fecha de caducidad	Se encontro que el usuario “temporal” no tiene configurado una caducidad	Cuenta vigente indefinidamente	sudo chage -E 2026-10-31 temporal	Imagen 5
Volumen de clientes sin cifrar	Mediante “lsblk -f” se encontró que sdb1-ext4 montado en /datos_teocelonet, sin crypto_LUKS	Robo del disco o copia de la VM expone los datos en claro	Cifrar la partición con LUKS2	Imagen 6

La imagen muestra a los usuarios creados con ID 1000 o superior que indica que fueron creados y no pertenecen a un servicio. Además se muestra que usuarios pertenecen al grupo sudo y por tanto pueden ejecutar acciones como root.

```
vboxuser@examen-servicios:~$ awk -F: '$3==0 {print $1}' /etc/passwd
root
vboxuser@examen-servicios:~$ awk -F: '$3>=1000 {print $1,$3,$7}' /etc/passwd
nobody 65534 /usr/sbin/nologin
vboxuser 1000 /bin/bash
adminsys 1001 /bin/bash
Soporte 1002 /bin/bash
soporte 1003 /bin/bash
temporal 1004 /bin/bash
vboxuser@examen-servicios:~$ getent group sudo; getent group wheel
sudo:x:27:vboxuser,adminsys,soporte
```

Imagen 1

Se muestra un listado de los servicios activos, mostrando la IP, el puerto y de más información.

```
vboxuser@examen-servicios:~$ sudo ss -tulpn
Netid State   Recv-Q  Send-Q      Local Address:Port   Peer Address:Port Process
udp   UNCONN  0       0              127.0.0.54:53          0.0.0.0:*     users:(("systemd-resolve",pid=518,fd=18))
udp   UNCONN  0       0           127.0.0.53%lo:53          0.0.0.0:*     users:(("systemd-resolve",pid=518,fd=16))
udp   UNCONN  0       0        10.0.2.15%enp0s3:68          0.0.0.0:*     users:(("systemd-network",pid=875,fd=35))
udp   UNCONN  0       0               127.0.0.1:323         0.0.0.0:*     users:(("chronyd",pid=1155,fd=4))
udp   UNCONN  0       0                   [::1]:323            [::]:*     users:(("chronyd",pid=1155,fd=5))
tcp   LISTEN  0       4096              0.0.0.0:22          0.0.0.0:*     users:(("sshd",pid=1094,fd=3),("systemd",pid=1,fd=100))
tcp   LISTEN  0       4096        127.0.0.53%lo:53          0.0.0.0:*     users:(("systemd-resolve",pid=518,fd=17))
tcp   LISTEN  0       4096           127.0.0.54:53          0.0.0.0:*     users:(("systemd-resolve",pid=518,fd=19))
tcp   LISTEN  0       511                  *:80                *:*     users:(("apache2",pid=1238,fd=4),("apache2",pid=1237,fd=4),("apache2",pid=1029,fd=4))
tcp   LISTEN  0       4096              [::]:22             [::]:*     users:(("sshd",pid=1094,fd=4),("systemd",pid=1,fd=101))
vboxuser@examen-servicios:~$
```

Imagen 2

Se hace un listado general de los servicios activos en el servidor.

```
vboxuser@examen-servicios:~$ systemctl list-units --type=service --state=running
  UNIT                          LOAD   ACTIVE SUB     DESCRIPTION
  apache2.service               loaded active running The Apache HTTP Server
  chrony.service                loaded active running chrony, an NTP client/server
  cron.service                  loaded active running Regular background program processing daemon
  dbus.service                  loaded active running D-Bus System Message Bus
  fwupd.service                 loaded active running Firmware update daemon
  getty@tty1.service            loaded active running Getty on tty1
  ModemManager.service          loaded active running Modem Manager
  multipathd.service            loaded active running Device-Mapper Multipath Device Controller
  networkd-dispatcher.service loaded active running Dispatcher daemon for systemd-networkd
  polkit.service                loaded active running Authorization Manager
  rsyslog.service               loaded active running System Logging Service
  snapd.service                 loaded active running Snap Daemon
  ssh.service                   loaded active running OpenBSD Secure Shell server
  systemd-journald.service      loaded active running Journal Service
  systemd-logind.service        loaded active running User Login Management
  systemd-networkd.service      loaded active running Network Management
  systemd-resolved.service      loaded active running Network Name Resolution
  systemd-udevd.service         loaded active running Rule-based Manager for Device Events and Files
  udisks2.service               loaded active running Disk Manager
  unattended-upgrades.service loaded active running Unattended Upgrades Shutdown
  upower.service                loaded active running Daemon for power management
  user@1000.service             loaded active running User Manager for UID 1000

Legend: LOAD   → Reflects whether the unit definition was properly loaded.
        ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
        SUB    → The low-level unit activation state, values depend on unit type.

22 loaded units listed.
```

Imagen 3

Se verifica el status de UFW e iptables

```
vboxuser@examen-servicios:~$ sudo ufw status verbose;
Status: inactive
vboxuser@examen-servicios:~$ sudo iptables -L -n -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
```

Imagen 4

Se puede observar la información del usuario “temporal” el cual no presenta configuraciones como caducidad en la contraseña y caducidad en el usuario mismo.

```
vboxuser@examen-servicios:~$ sudo chage -l temporal
Last password change                                    : Oct 12, 2026
Password expires                                        : never
Password inactive                                       : never
Account expires                                         : never
Minimum number of days between password change          : 0
Maximum number of days between password change          : 99999
Number of days of warning before password expires       : 7
```

Imagen 5

Se observa que la partición datos_teocelonet están en un formato EXT4 sin cifrar.



Imagen 6

- ¿Cuál de los riesgos encontrados consideras que representaba el mayor peligropara MercadoNova y por qué?

El mayor peligro fue la combinación de privilegios excesivos con cuentas mal controladas y la ausencia de firewall. La cuenta de soporte pertenecía al grupo sudo, por lo que podía ejecutar cualquier comando como root, y la cuenta temporal no tenía fecha de expiración, de modo que seguía vigente aunque ya no hubiera necesidad.

Como el firewall estaba inactivo (policy ACCEPT y sin reglas), cualquier servicio que se levantara por error quedaba expuesto. Basta con comprometer una de estas cuentas (por contraseña débil, reutilizada o filtrada) para obtener control total del servidor: leer los datos de clientes, modificar la configuración del sitio o detener el servicio. Es un riesgo que afecta a la confidencialidad, integridad y disponibilidad a la vez, y que multiplica el impacto de cualquier otro fallo, por eso lo considero más grave que un hallazgo aislado.

- ¿Qué riesgo relevante continúa existiendo aun después de aplicar loscontroles?

Aun con los controles aplicados, permanece el riesgo de robo o mal uso de credenciales legítimas. Los administradores que conservan sudo como vboxuser y adminsys siguen siendo un punto único de falla:

si se roba su llave privada, se compromete su equipo o se les engaña con phishing, el atacante entra por un canal autorizado y el firewall, SSH y los permisos no lo detienen.

Otro riesgo es el que ya describe el análisis de almacenamiento: con el volumen LUKS desbloqueado, cualquier proceso comprometido o usuario con privilegios puede leer clientes.txt en claro, porque el cifrado solo protege el disco apagado o robado.